

Vulnerability Scanning

What is Vulnerability Scanning?

- Automated process to find security weaknesses in systems.
- Helps identify outdated software, misconfigurations, and missing patches.

Discovery / Reconnaissance vs Scanning

- Discovery/Recon → Information gathering (open ports, services).
- Scanning → Testing those services for known vulnerabilities.

-  **Authenticated vs Unauthenticated Scans**
- Authenticated → Uses valid login (deeper checks, accurate results).
- Unauthenticated → External view, limited but faster, attacker perspective.

Types of Scans & Attack Surfaces

- Network scans (ports, services).
- Web app scans (SQLi, XSS).
- Host scans (patches, configs).
- Cloud/IoT scans.

Vulnerability vs Exploit vs PoC

- Vulnerability → Weakness.
- Exploit → Code/technique to take advantage.
- PoC → Demonstration that exploit works.

False Positives / False Negatives & Tuning

- False Positive → Reports issue that doesn't exist.
- False Negative → Misses real issue.
- Tuning reduces noise & improves accuracy.



Severity, CVSS, CVE, CWE

- Severity → Impact level.
- CVSS → Scoring system (0–10).
- CVE → Public ID for a vulnerability.
- CWE → Weakness category.

Risk Prioritization & Remediation Workflow

- Rank vulnerabilities by risk (critical first).
- Assign fixes to teams.
- Patch, re-scan, verify.

Reporting: What to Include

- Summary for management.
- Technical details for IT/security team.
- Risk ratings, remediation steps, screenshots/logs.

Tools Map & When to Use

- Nikto → Web server/app scanning.
- OpenVAS → Free, open-source, full-featured.
- Nessus → Industry standard, enterprise use.